

BÁO CÁO THỰC TẬP TỐT NGHIỆP ĐẠI HỌC

Mô-đun AI cục bộ hỗ trợ phân tích cảnh báo SIEM

Nghiên cứu và xây dựng mô-đun AI cục bộ hỗ trợ phân tích và giải thích cảnh báo an ninh trên hệ thống SIEM

Nhóm A07

Đinh Tuấn Dương • N22DCAT014

Nguyễn Trung Nguyên • N22DCAT039

Lớp · Ngành

D22CQAT01-N · An toàn thông tin

Hướng dẫn

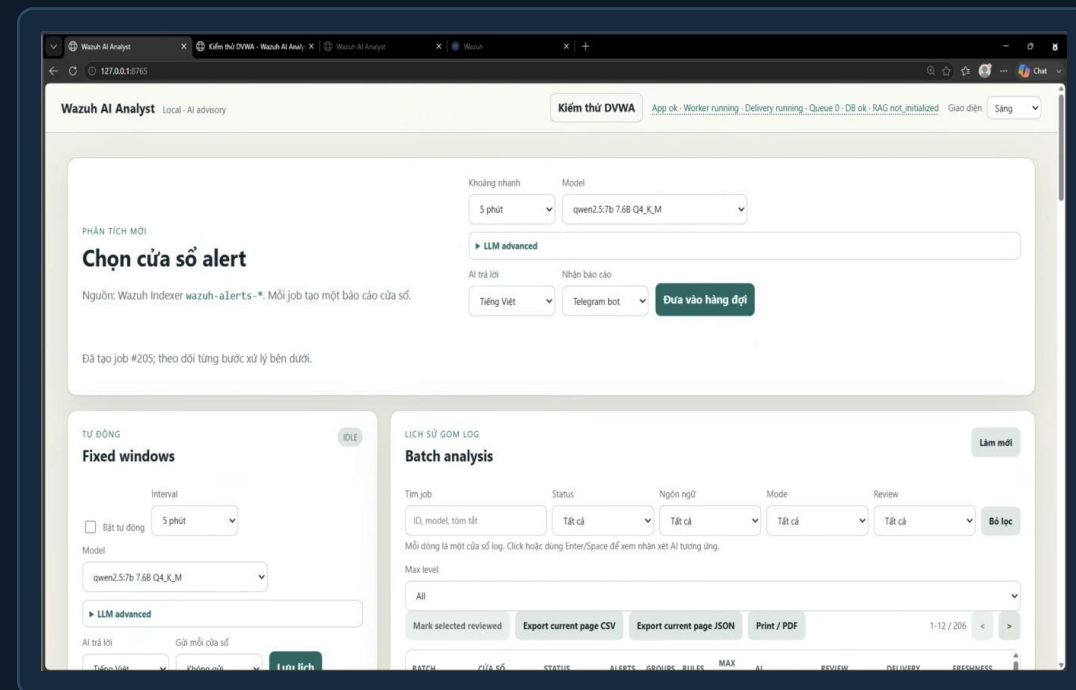
ThS. Nguyễn Hoàng Thành

Đơn vị

Khoa CNTT 2 — Học viện CNBCVT, cơ sở TP.HCM

Thời gian

TP. Hồ Chí Minh, tháng 8/2026



Giao diện mô-đun AI cục bộ · 127.0.0.1:8765

Mục tiêu là rút ngắn bước phân loại ban đầu, không thay quyết định của người

CẢNH BÁO WAZUH THÔ

```
{
  "rule": { "id": "5710", "level": 5,
    "description": "Attempt to login using a
      non-existent user",
    "groups": ["syslog","sshd",
      "authentication_failed"],
    "mitre": { "id": ["T1110"] } },
  "agent": { "id": "002", "name": "victim-ubuntu" },
  "data": { "srcip": "10.0.0.30", "srcport": "54122" },
  "decoder": { "name": "sshd" },
  "location": "/var/log/auth.log",
  "full_log": "sshd[2841]: Invalid user admin
    from 10.0.0.30 port 54122 ssh2"
}
```



AI cục bộ

BẢN DIỄN GIẢI CÓ CẤU TRÚC

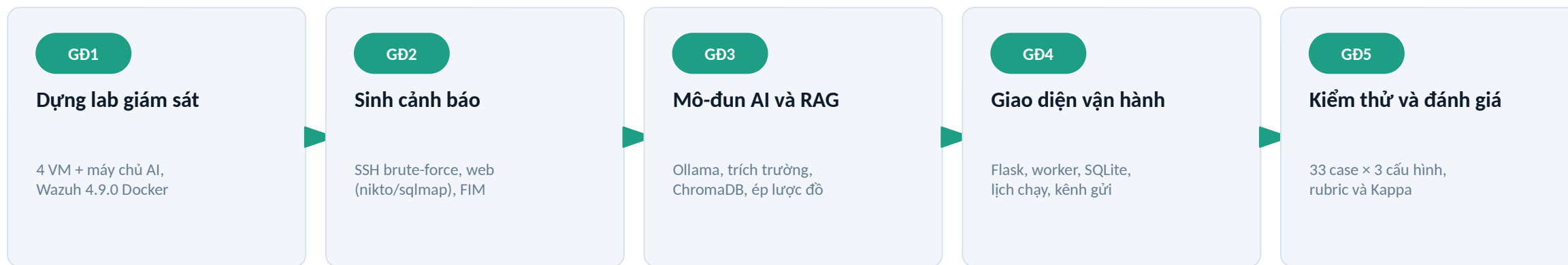
Tóm tắt	Nhiều lần đăng nhập SSH bằng tài khoản không tồn tại từ một nguồn duy nhất.
Nguyên nhân	Luật 5710 kích hoạt khi sshd ghi nhận user không tồn tại — dấu hiệu dò tài khoản.
Mức nghiêm trọng	medium (luật quy định: 5 — Thấp)
MITRE ATT&CK	T1110 — Brute Force
Bước kiểm tra	1. Đối chiếu số lần thất bại trong cửa sổ. 2. Kiểm tra có phiên thành công sau đó. 3. Cân nhắc giới hạn tốc độ SSH.
Căn cứ đánh giá	Tách rõ sự kiện quan sát / suy luận / điểm bất định / giới hạn dữ liệu.

Đọc cảnh báo tự động
trực tiếp từ Wazuh Indexer

Diễn giải • phân loại • ánh xạ MITRE
kèm bước kiểm tra tiếp theo

Toàn bộ xử lý trong hạ tầng nội bộ
không gửi ra dịch vụ đám mây

Đề tài được triển khai qua năm giai đoạn có thể kiểm chứng



HOÀN TẤT

- Lab Wazuh 4.9.0, agent Ubuntu và Windows, ba kịch bản sinh cảnh báo
- Mô-đun AI cục bộ, truy xuất tăng cường, ràng buộc lược đồ và dự phòng
- Giao diện vận hành, lưu trữ SQLite, lịch chạy và kênh gửi kết quả
- 33 case × 3 cấu hình = 99 lượt kết quả; hai người chấm độc lập, tính Kappa

CÒN GIỚI HẠN

- Chưa có chuyên gia SOC ngoài nhóm chấm độc lập
- Chưa đo thời gian phân tích tay để so sánh
- Kho tri thức mới có 19 tài liệu tham chiếu

Bốn lớp nối tiếp, dữ liệu thu hẹp dần và không có đường tắt tới mô hình

Lớp 1 — Nguồn dữ liệu

Wazuh Indexer 192.168.100.10:9200 · Manager API :55000 không nằm trong luồng dữ liệu

Lớp 2 — Xử lý · bốn thành phần nối tiếp, mỗi thành phần một tệp mã nguồn

reader.py

extractor.py

rag.py

llm.py

nhánh tùy chọn

Lớp 3 — Phục vụ mô hình

Ollama localhost:11434 · nomic-embed-text + qwen2.5:7b · chặn kết nối ngoài localhost

Xác thực lược đồ / kết quả dự phòng

Chuỗi kiểm tra 10 bước; thất bại → severity = unknown kèm lý do

Lớp 4 — Điều phối và giao diện

analysis_service → dashboard_worker → SQLite → dashboard · review, xuất JSON, Telegram/Gmail

BỐN QUYẾT ĐỊNH THIẾT KẾ

1

Alert lấy từ Indexer :9200

Manager API :55000 chỉ phục vụ quản trị, không trả cảnh báo theo điều kiện tìm kiếm.

2

Ranh giới tin cậy tường minh

Cảnh báo, log gốc và ngữ cảnh truy xuất đều thuộc vùng không đáng tin cậy.

3

Toàn bộ xử lý trong nội bộ

Hàm kết nối Ollama từ chối hoạt động nếu địa chỉ không phải localhost.

4

Mô-đun chỉ hỗ trợ diễn giải

Không tự động cảnh báo, không leo thang, không thực hiện hành động phản ứng.

Mỗi cảnh báo đi qua sáu bước, kết thúc bằng bước rà soát của người



Nhánh tùy chọn — truy xuất tri thức: ChromaDB top-3, ngưỡng khoảng cách $\leq 1,0$. Lỗi thì bỏ qua, không chặn luồng chính.

Điểm human-in-the-loop duy nhất: người phân tích rà soát rồi đóng cảnh báo hoặc leo thang.

Không đưa bản ghi JSON gốc vào mô hình — chỉ các trường đã trích chọn lọc. Nội dung phản hồi thô không được lưu lại để tránh log độc hại bị hiểu sai lan truyền tiếp.

Toàn bộ chuỗi công cụ chạy được trên một máy phổ thông

Lớp	Công nghệ và phiên bản	Vai trò trong hệ thống
SIEM	Wazuh 4.9.0 — Manager, Indexer, Dashboard	Thu thập log từ agent, đối sánh luật, sinh và lưu cảnh báo
Hạ tầng lab	VMware Workstation 17 Pro • Docker 29.6.1 / Compose v5.3.1	Bốn máy ảo trên mạng host-only 192.168.100.0/24
Mô hình	Ollama 0.6.2 • qwen2.5:7b (7,61 tỷ, Q4_K_M, 4,7 GB)	Suy luận cục bộ; đối chứng CyberCrew/notmythos-8b (~3,2 tỷ)
Truy xuất tri thức	nomic-embed-text • ChromaDB PersistentClient	19 đoạn tri thức, top-3 mỗi lần, ngưỡng khoảng cách 1,0
Xử lý	Python 3.12.7 • Flask	Pipeline phân tích, API cục bộ và worker xử lý nền
Lưu trữ	SQLite — dashboard.db	Job, kết quả, đánh giá chỉ-ghi-thêm và nhật ký kiểm toán
Giao diện	HTML / CSS / JavaScript thuần	Dashboard phục vụ tại 127.0.0.1:8765
Kênh báo cáo	JSON • PDF • Telegram • Gmail (tùy chọn)	Chỉ gửi bản tóm tắt đã lọc bỏ thông tin nhạy cảm

Ràng buộc không rời hạ tầng nội bộ được ép cứng ngay ở tầng mã nguồn: hàm kết nối tới Ollama từ chối hoạt động nếu địa chỉ không phải localhost, trừ khi được chủ động cho phép.

Đầu ra được ép thành cấu trúc và phải bám bằng chứng

LƯỢC ĐỒ JSON BẮT BUỘC

```
{
  "summary": "...",
  "root_cause": "...",
  "severity": "low | medium | high",
  "mitre": ["T1110"],
  "next_steps": ["..."],
  "assessment_basis": {
    "observed": [...], // sự kiện quan sát
    "inference": [...], // suy luận
    "uncertainty": [...], // điểm bất định
    "limitation": [...] // giới hạn dữ liệu
  }
}
```

Hai lớp ép cấu trúc: chỉ dẫn bằng văn bản trong system prompt, và tham số format của Ollama nhận trực tiếp JSON Schema đầy đủ.

BA LỚP CHỐNG CHÈN CHỈ DẪN ĐỌC HẠI

1 Phân tách cấu trúc

Dữ liệu cảnh báo và ngữ cảnh truy xuất luôn nằm ở vai trò user message, tách khỏi chỉ dẫn hệ thống

2 Đánh dấu tường minh

Bọc trong ranh giới <UNTRUSTED> kèm khẳng định đây là bằng chứng, không phải chỉ dẫn để làm theo

3 Giới hạn quyền

Mô hình không có khả năng thực thi; thiệt hại tối đa chỉ là một kết quả diễn giải sai

Ghi vết: 5 giá trị băm SHA-256 (chỉ dẫn, đầu vào, lược đồ, phản hồi, ngữ cảnh) — không lưu văn bản gốc

Đầu ra sai hợp đồng không được trả về như kết quả bình thường: hệ thống chuyển sang kết quả dự phòng và nêu rõ lý do thất bại, thay vì đưa ra một câu trả lời trông có vẻ đúng.

Giao diện đưa mô-đun từ một lệnh dòng lệnh thành quy trình dùng được

1

Phân tích theo cửa sổ thời gian

Chọn khoảng, mô hình và ngôn ngữ đầu ra; mỗi job tạo một báo cáo cửa sổ.

2

Lịch chạy theo cửa sổ cố định

Có độ trễ nạp dữ liệu và giới hạn bù đắp khi hệ thống bị gián đoạn.

3

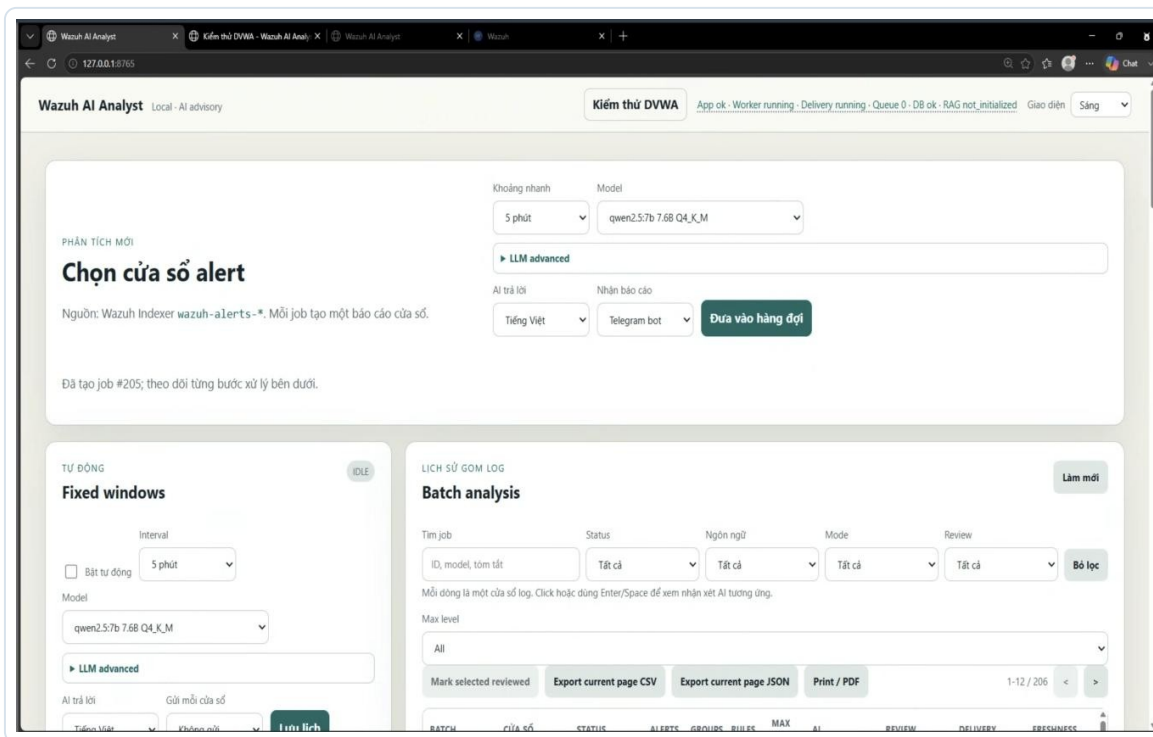
Rà soát Case-lite

Người phân tích chỉnh mức, gắn nhãn, ghi chú — lưu tách biệt với khuyến nghị AI.

4

Xuất JSON / PDF và gửi thông báo

Telegram hoặc Gmail ở chế độ tùy chọn, chỉ gửi bản đã lọc thông tin nhạy cảm.



Giao diện chính của mô-đun tại 127.0.0.1:8765 — chọn cửa sổ, mô hình, ngôn ngữ và kênh nhận báo cáo

Đã kiểm chứng trên lab: một cửa sổ 24 giờ điển hình ghi nhận khoảng 580 cảnh báo; giao diện xử lý theo lô và giữ nguyên lịch sử job sau khi khởi động lại ứng dụng.

Cảnh báo không nằm ở nơi thiết kế ban đầu dự kiến

1

Wazuh có ba đường truy cập dễ nhầm

Tệp alerts.json cục bộ trên Manager; Wazuh API cổng 55000 chỉ phục vụ quản trị; Indexer API cổng 9200 mới là nơi lưu và tìm kiếm được cảnh báo.

2

Khối lượng cảnh báo lớn hơn mức cần diễn giải

Chỉ riêng lab nhỏ, một cửa sổ 24 giờ đã ghi nhận khoảng 580 cảnh báo. Đưa nguyên bản ghi JSON vào mô hình vừa tốn token vừa làm giảm độ chính xác.

3

Log gốc do kẻ tấn công điều khiển một phần

Tên tài khoản đăng nhập, chuỗi user-agent hay đường dẫn HTTP đều do bên ngoài đặt — có thể chứa văn bản giống chỉ dẫn hệ thống.

Một ranh giới năng lực khác cũng được xác định trong quá trình thử nghiệm: quét cổng bằng nmap không sinh ra cảnh báo nào, vì Wazuh giám sát dựa trên máy chủ và phân tích nhật ký chứ không phân tích lưu lượng mạng.

Đọc có điều kiện từ Indexer, trích chọn lọc trước khi chạm tới mô hình

- 1 Truy vấn Indexer API cổng 9200** POST /wazuh-alerts-*/_search; thông tin xác thực Indexer tách riêng khỏi Wazuh API.
- 2 Hai chế độ tiếp nhận** Theo lô cho đánh giá và gần thời gian thực cho vận hành, dùng chung một đường xử lý.
- 3 Chống trùng theo mã cảnh báo** Mỗi cảnh báo mang mã định danh duy nhất; mô-đun lưu lại mã đã xử lý.
- 4 Nối lại đúng vị trí sau gián đoạn** Ghi mốc thời gian truy vấn gần nhất để không bỏ sót cảnh báo phát sinh khi mất kết nối.
- 5 Trích 10 trường theo khai báo cấu hình** Định danh luật, mức độ, thực thể liên quan, thời gian và tri thức MITRE đính kèm.
- 6 Làm phẳng thành văn bản ngắn** Loại bỏ trường vận hành nội bộ của Wazuh — không có giá trị phân tích, chỉ làm dài ngữ cảnh.

MÃ NGUỒN DẪN CHIẾU

`ai_module/reader.py``ai_module/extractor.py``ai_module/analysis_service.py`

Tiêu chí chọn trường: một trường chỉ được đưa vào nếu nó phục vụ trực tiếp một trong bốn nhiệm vụ diễn giải — tóm tắt, nguyên nhân, mức nghiêm trọng, bước kiểm tra.

Mô hình có thể sinh nội dung hợp lý nhưng không có căn cứ

1

Bịa tên hoặc mã kỹ thuật MITRE

6/20 case chấm tay (30%). Ví dụ: T1053.002 bị gán sai tên ở case benign-503-01; T1070.002 sai tên ở case fim-554-02.

2

Gán mã tấn công cho sự kiện lành tính

4/20 case (20%). Ví dụ: T1190 bị gán cho một thông báo về lỗi hỏng đã được vá ở case benign-23502-01 và -02.

3

Suy diễn vượt quá dữ liệu quan sát được

3/20 case (15%). Ví dụ: kết luận "đang bị dò mật khẩu" chỉ từ một lần đăng nhập thất bại ở case ssh-5760-03.

Chỉ chạy mô hình cục bộ là chưa đủ. Cần tri thức tham chiếu có nhãn nguồn để đối chiếu ngược, ràng buộc lược đồ kèm cơ chế dự phòng, và ghi vết toàn bộ quá trình bằng giá trị băm.

Tri thức tham chiếu, ràng buộc lược đồ và ghi vết tạo thành ba lớp kiểm soát

1 Tri thức tham chiếu

- ChromaDB cục bộ, embedding bằng nomic-embed-text
- Truy vấn theo mã luật, mô tả luật và mã kỹ thuật MITRE nếu có sẵn
- Mỗi đoạn kèm nhãn nguồn tường minh để đối chiếu ngược khi mô hình đưa nhận định

2 Ràng buộc lược đồ

- Chỉ dẫn hệ thống được phiên bản hóa: soc-contract-v1
- Tham số format của Ollama nhận trực tiếp JSON Schema đầy đủ
- Nhiệt độ 0 và seed cố định để kết quả tái lập được giữa các lần chạy

3 Xác thực và ghi vết

- Chuỗi kiểm tra 10 bước: JSON → object → khóa → kiểu → giá trị enum
- Thất bại ở bất kỳ bước nào đều trả kết quả dự phòng kèm lý do
- Lưu 5 giá trị băm SHA-256 và phiên bản chỉ dẫn, không lưu văn bản gốc

THÔNG SỐ KHO TRI THỨC ĐÃ XÂY DỰNG

19

đoạn đã đánh chỉ mục

3

đoạn truy xuất mỗi lần

1,0

ngưỡng khoảng cách

2,95 s

đánh chỉ mục toàn bộ

MÃ NGUỒN DẪN CHIẾU

```
ai_module/rag.py  
ai_module/llm.py  
ai_module/create_rag_data.py
```

Một lệnh dòng lệnh chứng minh được khả thi nhưng chưa dùng lặp lại được

1

Chọn cửa sổ, mô hình và ngôn ngữ

Người phân tích phải đối được tham số mà không sửa mã nguồn.

2

Theo dõi trạng thái xử lý thật

Biết job đang ở bước nào, không phải đoán qua nhật ký terminal.

3

Xem lại kết quả cũ

Kết quả phải còn sau khi tải lại trang và sau khi khởi động lại ứng dụng.

4

Ghi nhận đánh giá của người

Điều chỉnh mức, gắn nhãn, ghi chú — lưu tách biệt với khuyến nghị của mô hình.

5

Xử lý lặp lại theo lịch

Sau gián đoạn phải chạy tiếp từ đúng mốc, không bỏ sót và không xử lý trùng.

API cục bộ, worker và SQLite hợp thành một quy trình có thể truy vết

1 Flask phục vụ trên loopback

Chỉ lắng nghe tại 127.0.0.1:8765, không proxy thông tin xác thực xuống trình duyệt.

2 Worker xử lý nền

Theo dõi phase thật của pipeline, không chèn hiệu ứng chờ giả.

3 SQLite lưu toàn bộ trạng thái

Job, kết quả, đánh giá và nhật ký kiểm toán, tách biệt với dữ liệu cảnh báo gốc.

4 Đánh giá chi-ghi-thêm

Mỗi lần điều chỉnh tạo bản ghi mới thay vì ghi đè — truy vết được ai sửa gì, khi nào.

5 Lịch chạy theo cửa sổ cố định

Có độ trễ nạp dữ liệu và giới hạn bù đắp, tránh dồn một lượng lớn cảnh báo cũ.

6 Kênh gửi tùy chọn

Telegram và Gmail chỉ nhận bản tóm tắt đã lọc; thông tin xác thực lưu cục bộ.

MÃ NGUỒN DẪN CHIẾU

```
ai_module/dashboard.py
```

```
ai_module/dashboard_worker.py
```

```
ai_module/dashboard_store.py
```

```
ai_module/web/
```

Lược đồ cơ sở dữ liệu được quản lý theo phiên bản (migration đánh số), cho phép nâng cấp cấu trúc mà không mất lịch sử đã lưu.

Một phép đo dễ dãi sẽ cho kết quả đẹp nhưng vô nghĩa

1

Nhãn chuẩn không được suy ra từ mức luật

Nếu suy ra, một quy tắc tầm thường "trả về đúng nhóm mức của luật" sẽ đạt độ chính xác tuyệt đối.

2

Nhãn hiện vẫn là bản nháp, một người rà soát

Đã qua một vòng rà soát kỹ thuật nội bộ nhưng chưa có người thứ hai độc lập phân xử.

3

Điểm trung bình che lấp hướng sai lệch

Thang 1–5 không cho biết mô hình đánh giá quá nặng hay quá nhẹ, và sai ở nhóm cảnh báo nào.

4

Chấm điểm chủ quan cần chứng minh đồng thuận

Phải chứng minh hai người chấm thực sự đồng thuận, không phải trùng nhau do ngẫu nhiên.

5

Cỡ mẫu 33 case là nhỏ

Chênh lệch vài case đã đủ làm thay đổi tỷ lệ phần trăm — cần kiểm định ghép cặp và khoảng tin cậy.

QUY MÔ PHÉP ĐO

33

cảnh báo đã làm sạch
thông tin định danh

99

lượt kết quả
trên ba cấu hình

100

cặp điểm chấm tay
20 case × 5 tiêu chí

nhãn chuẩn: bản nháp, một người rà soát

Ba cấu hình trên cùng bộ dữ liệu tách bạch hai phép so sánh độc lập

Giữ cố định: cùng 33 cảnh báo · cùng chỉ dẫn soc-contract-v1 · cùng lược đồ đầu ra · nhiệt độ 0 và seed cố định

A qwen2.5:7b + RAG

Cấu hình chuẩn

B qwen2.5:7b không RAG

Đo ảnh hưởng của truy xuất tăng cường

C notmythos-8b + RAG

Đo khác biệt giữa hai mô hình

Đối chứng thứ tư — đường cơ sở không dùng mô hình ngôn ngữ: quy tắc trả về nhóm mức tương ứng với giá trị rule.level của luật đã kích hoạt, để tách phần đóng góp thực sự của khâu diễn giải khỏi thông tin cảnh báo vốn đã cung cấp sẵn.

MÃ NGUỒN DẪN CHIẾU

`eval/run_eval.py`

`eval/summarize_results.py`

`eval/stats_analysis.py`

`eval/export_confusion_matrix.py`

Trường hợp mô hình từ chối phân loại được giữ thành một cột riêng, không bị loại khỏi mẫu — nếu loại bỏ, tỷ lệ đúng sẽ bị thổi từ 66,7% lên 68,8%.

Đề tài tạo ra cả hệ thống, bộ dữ liệu và quy trình kiểm chứng

Hạ tầng thử nghiệm

4 máy ảo + máy chủ AI

- Wazuh 4.9.0 single-node bằng Docker, mạng host-only
- Agent trên máy nạn nhân Ubuntu và Windows
- Ba kịch bản sinh cảnh báo đóng gói thành tệp lệnh
- Nhật ký sáu sự cố triển khai và cách khắc phục

Mô-đun AI

ai_module/ + giao diện web

- Bốn thành phần nối tiếp: đọc, trích xuất, truy xuất, gọi mô hình
- Kho tri thức 19 đoạn từ luật Wazuh và MITRE ATT&CK
- Giao diện vận hành, lưu trữ SQLite, lịch chạy tự động
- Kênh gửi JSON, PDF, Telegram và Gmail

Bộ dữ liệu đánh giá

33 case • 99 lượt kết quả

- 33 cảnh báo thật đã làm sạch thông tin định danh
- Hồ sơ kỳ vọng riêng cho từng case: tính chất, mức, MITRE
- Ba cấu hình chạy trên cùng bộ dữ liệu cố định
- Toàn bộ đóng băng trong kho mã nguồn, chạy lại được

Quy trình kiểm chứng

8 FR • rubric 5 tiêu chí

- Bộ quy tắc chấm mô tả rõ từng bậc điểm cho 5 tiêu chí
- Chấm độc lập hai người, tính hệ số đồng thuận Cohen's Kappa
- Ma trận nhầm lẫn, kiểm định McNemar, khoảng tin cậy Wilson
- Đường cơ sở đối chứng không dùng mô hình ngôn ngữ

Đóng góp chính không nằm ở việc chứng minh mô hình ngôn ngữ có thể diễn giải cảnh báo, mà ở việc xác định các ràng buộc kỹ thuật cần thiết để kết quả diễn giải trở nên kiểm chứng được.

Tám mục tiêu thiết kế đều gắn với một tiêu chí kiểm chứng cụ thể

Mục tiêu thiết kế	Tiêu chí kiểm chứng	Kết quả
Đọc cảnh báo trực tiếp từ Wazuh, không thao tác thủ công	Chạy được với dữ liệu thật	Đạt
Chỉ đưa trường đã trích xuất có chọn lọc vào mô hình	Đối chiếu mã nguồn với danh sách trường	Đạt
Đầu ra theo cấu trúc cố định, kiểm tra được bằng máy	Tỷ lệ hợp lệ theo lược đồ	33/33 đúng lược đồ
Mọi nhận định bám dữ liệu cụ thể, không suy diễn	Đối chiếu khối căn cứ đánh giá	Đạt có điều kiện
Xử lý trong hạ tầng nội bộ, không gửi dữ liệu ra ngoài	Kiểm tra cấu hình kết nối trong mã nguồn	Đạt
Kết quả tái lập được với cùng đầu vào	So sánh nhiều lần chạy	Đạt về thiết kế
Thời gian xử lý phù hợp gần thời gian thực	Đo độ trễ trên 33 cảnh báo	2,716 giây
Không thực hiện hành động thay đổi trạng thái hệ thống	Rà soát quyền hạn trong mã nguồn	Đạt

YÊU CẦU HỆ THỐNG

13

yêu cầu chức năng đã khai báo (FR-01 ... FR-13)

8

yêu cầu đưa vào ca kiểm thử — đạt 8/8

8

yêu cầu phi chức năng (NFR-01 ... NFR-08)

6

ca kiểm thử TC-01 ... TC-06

Hai mục tiêu chỉ đạt có điều kiện: 3/20 case chấm tay còn suy diễn vượt quá dữ liệu quan sát được; và tính tái lập mới bảo đảm ở mức thiết kế (nhiệt độ 0, seed cố định) chứ chưa chạy lặp nhiều lượt để đo tỷ lệ trùng khớp thực tế.

Chỉ số được chọn để đo cả tính đúng, độ tin cậy và chi phí vận hành

Nhóm	Chỉ số	Câu hỏi mà chỉ số trả lời
Chức năng	FR-01 ... FR-08 đạt / không đạt	Hệ thống có chạy đúng yêu cầu đã đặt ra không
Hợp đồng đầu ra	Tỷ lệ đúng lược đồ, tỷ lệ dùng kết quả dự phòng	Đầu ra có ổn định về mặt cấu trúc không
Phân loại	Tỷ lệ khớp mức nghiêm trọng, độ chính xác theo lớp	Mô hình gán mức nghiêm trọng đúng đến đâu
Hướng sai lệch	Ma trận nhầm lẫn — đánh giá cao hơn / thấp hơn mức chuẩn	Mô hình sai theo hướng nào và sai ở nhóm nào
Chất lượng diễn giải	Rubric 5 tiêu chí, thang 1-5	Nội dung diễn giải có dùng được không
Độ tin cậy phép chấm	Cohen's Kappa có trọng số bậc hai	Hai người chấm có thực sự đồng thuận không
Bảng chứng thống kê	McNemar ghép cặp + khoảng tin cậy Wilson 95%	Chênh lệch giữa hai cấu hình có đủ bằng chứng không
Hiệu năng	Độ trễ trung bình / trung vị / p95, RAM, VRAM, token	Có chạy được trên phần cứng phổ thông không
Đối chứng	Đường cơ sở không dùng mô hình ngôn ngữ	Khâu diễn giải đóng góp thêm bao nhiêu

Nhóm cố ý không báo cáo một điểm tổng duy nhất: mỗi nhóm chỉ số trả lời một câu hỏi khác nhau, và như kết quả sẽ cho thấy, điểm trung bình che lấp đúng phần khác biệt quan trọng nhất.

Ba cấu hình được đo trên cùng bộ 33 cảnh báo

33 cảnh báo thật đã làm sạch thông tin định danh • đóng băng trong eval/cases/

13 thấp

13 trung bình

7 cao

A

qwen2.5:7b + RAG

B

qwen2.5:7b không RAG

C

notmythos-8b + RAG

99 lượt kết quả • đối chiếu ghép cặp trên từng case • kiểm định McNemar chính xác

PHÂN BỐ THEO NHÓM KỊCH BẢN

Lành tính (đối chứng)

13 • 39,4%

503 • 5402 • 5501 • 5502 • 5715 • 23502

Dò mật khẩu SSH

12 • 36,4%

2502 • 5503 • 5710 • 5712 • 5760 • 40112

Toàn vẹn tập tin (FIM)

3 • 9,1%

553 • 554

Tấn công web

3 • 9,1%

31101 • 31105 • 31151

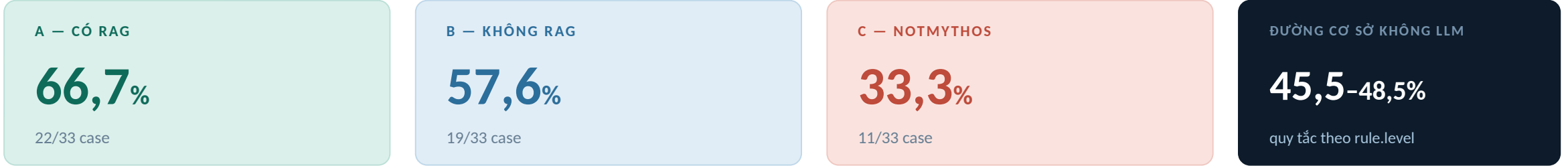
Trường hợp nhập nhầm

2 • 6,1%

506 • 510

Nhãn chuẩn được gán dựa trên nội dung nhật ký gốc và ngữ cảnh kịch bản, cố ý KHÔNG suy ra từ giá trị rule.level — nếu suy ra, phép đo sẽ trở nên vô nghĩa.
Nhãn hiện ở trạng thái bản nháp, một người rà soát; chưa có người thứ hai độc lập phân xử.

Truy xuất tăng cường cải thiện rõ ở nhóm nghiêm trọng; khác biệt giữa hai mô hình lớn hơn nhiều



Cấu hình	Khớp mức chuẩn	Đánh giá cao hơn	Đánh giá thấp hơn	Từ chối phân loại
A — qwen2.5:7b, có RAG	22/33 — 66,7%	2 (6,1%)	8 (24,2%)	1 (3,0%)
B — qwen2.5:7b, không RAG	19/33 — 57,6%	4 (12,1%)	10 (30,3%)	0
C — notmythos-8b, có RAG	11/33 — 33,3%	7 (21,2%)	15 (45,5%)	0
Đường cơ sở không dùng LLM	15-16/33 — 45,5-48,5%	—	—	—

A so với B — ảnh hưởng của RAG: +9,1 điểm phần trăm; riêng nhóm nghiêm trọng nhận đúng tăng từ 1/7 lên 3/7. Kiểm định ghép cặp cho **p = 0,58** — xu hướng quan sát được, chưa phải bằng chứng.

A so với C — khác biệt mô hình: gấp đôi độ chính xác. Kiểm định ghép cặp cho **p = 0,0074** — đạt ý nghĩa thống kê. Khoảng tin cậy Wilson 95% của hai cấu hình gần như không chồng lấn.

Sai lệch nghiêng hẳn về phía đánh giá thấp, tập trung ở nhóm nghiêm trọng nhất

		Cấu hình A — có RAG						Cấu hình B — không RAG					
Mức chuẩn tham chiếu	thấp	10 (77%)	2 (15%)	0 (0%)	1 (8%)	n=13	thấp	9 (69%)	4 (31%)	0 (0%)	0 (0%)	n=13	
	trung bình	4 (31%)	9 (69%)	0 (0%)	0 (0%)	n=13	trung bình	4 (31%)	9 (69%)	0 (0%)	0 (0%)	n=13	
	cao	1 (14%)	3 (43%)	3 (43%)	0 (0%)	n=7	cao	0 (0%)	6 (86%)	1 (14%)	0 (0%)	n=7	
		thấp	trung bình	cao	từ chối phân loại		thấp	trung bình	cao	từ chối phân loại			
		Mức do mô hình dự đoán						Mức do mô hình dự đoán					
Hàng là mức chuẩn tham chiếu (bản nháp, một người rà soát). Mỗi ô ghi số case và tỷ lệ theo hàng; số in đậm là dự đoán khớp mức chuẩn.													

BỐN QUAN SÁT

Nhóm nghiêm trọng nhận đúng

3/7

không RAG chỉ 1/7

Bị đánh giá thấp hơn mức chuẩn

8/33 — 24,2%

hướng sai nguy hiểm nhất

Bị đánh giá cao hơn mức chuẩn

2/33 — 6,1%

ít hơn 4 lần

Từ chối phân loại

1/33 — 3,0%

giữ nguyên trong mẫu

Vì sao ma trận có 3 hàng nhưng 4 cột: hàng là mức nghiêm trọng mà cảnh báo thực sự thuộc về — luôn nằm trong ba mức do người gán. Cột là quyết định của hệ thống, gồm cả khả năng từ chối phân loại khi bằng chứng không đủ. Đây là dạng chuẩn của bài toán phân loại có quyền từ chối.

Nếu loại case từ chối phân loại khỏi mẫu, tỷ lệ đúng sẽ là $22/32 = 68,8\%$ thay vì $66,7\%$.

Nhóm giữ nguyên trong mẫu vì con số cao hơn sẽ che mất một dạng thất bại có thật.

Điểm trung bình cao ở phần diễn đạt lại, thấp ở phần đòi hỏi phán quyết

Tiêu chí	Không RAG	Có RAG	Chênh lệch
Tính chính xác của tóm tắt	3,94	3,94	0,00
Ảnh xạ kỹ thuật MITRE ATT&CK	4,36	4,21	-0,15
Tính hữu dụng của bước kiểm tra	3,64	3,85	+0,21
Tính đúng đắn của giải thích nguyên nhân	3,06	3,00	-0,06
Mức độ phù hợp của đánh giá nghiêm trọng	2,09	2,21	+0,12
Trung bình tổng	3,42	3,44	+0,02

Tiêu chí thấp nhất là mức nghiêm trọng (2,09-2,21): đây là nhiệm vụ duy nhất đòi hỏi mô hình đưa ra phán quyết thay vì diễn đạt lại thông tin đã có sẵn trong cảnh báo.

ĐỘ TIN CẬY CỦA CHÍNH PHÉP CHẤM

$\kappa = 0,223$ Cohen's Kappa có trọng số bậc hai

Mức Thấp · 20 case × 5 tiêu chí = 100 cặp điểm · đồng thuận quan sát 0,851, kỳ vọng ngẫu nhiên 0,809

Tóm tắt		0,456
Mức nghiêm trọng		0,423
Bước kiểm tra		0,361
Ảnh xạ MITRE		0,084
Giải thích nguyên nhân		-0,128

Hai tiêu chí đối chiếu được với dữ liệu khách quan đạt đồng thuận cao nhất; hai tiêu chí đòi hỏi phán đoán mở gần như không đồng thuận.

Vì hệ số đồng thuận chỉ ở mức thấp, nhóm chỉ dùng điểm trung bình 3,44/5 làm thông tin tham khảo. Căn cứ chính để kết luận là phép đối chiếu mức nghiêm trọng với nhãn chuẩn ở slide trước.

Chi phí vận hành nằm trọn trong giới hạn phần cứng phổ thông

ĐỘ TRỄ XỬ LÝ MỘT CẢNH BÁO

2,716 giây

trung bình có RAG · trung vị 2,704 · p95 3,897

Nhanh nhất	1,752 s	<i>benign-5502-02</i>
Chậm nhất	5,020 s	<i>ssh-5503-01</i>
Truy xuất tri thức	~0,08 s	<i>chỉ 3% tổng thời gian</i>
Gọi mô hình	~2,63 s	<i>phần chi phối</i>

TÀI NGUYÊN TIÊU THỤ

4,7 GB VRAM

trên card RTX 3070 Ti có 8 GB · RAM 4,5–6,0 GB

Token đầu vào	~520 / cảnh báo
Token đầu ra	~160 / cảnh báo
Chi phí của RAG	0,288 s — 10,6%
Dung lượng mô hình	4,7 GB (Q4_K_M)

Ý NGHĨA VẬN HÀNH

1,8%

năng lực lý thuyết đang dùng

Với 2,716 giây mỗi cảnh báo theo phương thức tuần tự, năng lực lý thuyết đạt khoảng 31.800 cảnh báo trong 24 giờ. Khối lượng thực tế ghi nhận trong lab là khoảng 580 cảnh báo mỗi 24 giờ.

31.800 là giá trị suy ra từ độ trễ đo trên 33 cảnh báo, chưa phải kết quả chạy liên tục 24 giờ.

KIỂM THỬ DƯỚI TÀI VẬN HÀNH THỰC TẾ — 40 CẢNH BÁO GỘP TRONG MỘT CỬA SỔ

 qwen2.5:7b	Thành công	Hợp lệ theo lược đồ	medium	13,91 s	Mô hình đối chứng nhanh hơn 20% và nhẹ hơn 53% VRAM trên từng cảnh báo đơn lẻ, nhưng không tuân thủ được lược đồ khi phải xử lý một lô cảnh báo gộp.
 notmythos-8b	Một phần	Rơi vào cơ chế dự phòng	không xác định	5,53 s	

Từ cảnh báo Wazuh đến bản phân tích có thể kiểm chứng

KỊCH BẢN 3 - 4 PHÚT

- 1 Mở Wazuh Dashboard, chỉ ra nhóm cảnh báo SSH / web / FIM
- 2 Mở giao diện mô-đun, chọn cửa sổ có dữ liệu và qwen2.5:7b
- 3 Chạy phân tích, theo dõi từng bước xử lý thật
- 4 Đọc tóm tắt, nguyên nhân, mức nghiêm trọng, MITRE, bước kiểm tra
- 5 Mở khối căn cứ đánh giá: quan sát / suy luận / bất định / giới hạn
- 6 Chỉ ra mức mô hình đề xuất hiển thị song song mức do luật quy định
- 7 Ghi nhận rà soát Case-lite, xuất JSON và mở lại lịch sử job

TIÊU CHÍ THÀNH CÔNG

- Job kết thúc ở trạng thái thành công
- Số cảnh báo khớp cửa sổ đã chọn
- Đầu ra đúng lược đồ, đủ sáu khối
- Có ghi vết bấm, không lộ thông tin xác thực
- Kết quả còn nguyên sau khi tải lại trang

PHƯƠNG ÁN DỰ PHÒNG

- Một cửa sổ dữ liệu đã biết chắc có cảnh báo
- Một job đã hoàn tất, mở lại được ngay
- Video quay sẵn 60 – 90 giây
- Không phụ thuộc việc gửi Telegram hay Gmail trực tiếp trong buổi bảo vệ

Chuẩn bị sẵn, không trình bày mặc định

Mười nội dung dưới đây chỉ mở khi hội đồng hỏi tới.

PL-1

Cấu hình phần cứng và phiên bản phần mềm

PL-2

Yêu cầu chức năng FR-01 ... FR-13 và phi chức năng

PL-3

Danh sách 33 case và nhãn tham chiếu

PL-4

Case truy xuất tăng cường làm tốt hơn / tệ hơn

PL-5

Cách tính McNemar và khoảng tin cậy Wilson

PL-6

Ranh giới tin cậy và năm nhóm rủi ro khi dùng LLM

PL-7

Sơ đồ mạng lab và cây thư mục mã nguồn

PL-8

Sáu sự cố khi triển khai và cách khắc phục

PL-9

Các lỗi thường gặp trong nội dung mô hình sinh ra

PL-10

Hạn chế và bốn hướng phát triển tiếp theo

Cấu hình phần cứng, phần mềm và hai mô hình ngôn ngữ

Máy chủ AI (máy vật lý)	Thông số
Bộ xử lý	Intel Core i7 gen 12 — 12700
Bộ nhớ RAM	32 GB
Card đồ họa / VRAM	NVIDIA GeForce RTX 3070 Ti — 8 GB
Hệ điều hành	Windows 11 Pro (build 10.0.26200)
Phục vụ mô hình	Ollama 0.6.2
Ngôn ngữ	Python 3.12.7
Ảo hóa	VMware Workstation 17 Pro
Container	Docker Engine 29.6.1 / Compose v5.3.1

Chỉ số	Mô hình chính (A, B)	Đối chứng (C)
Tên định danh Ollama	qwen2.5:7b	CyberCrew/notmythos-8b
Số tham số	7,61 tỷ	~3,2 tỷ
Mô hình nền	Qwen 2	Llama 3.2 — 3B
Mức lượng tử hóa	Q4_K_M	Q4_K_M
Dung lượng tệp mô hình	4,7 GB	2,0 GB
VRAM tiêu thụ	4,7 GB	2,5 GB
Thời gian trung bình	2,716 s	2,173 s
Tỷ lệ đầu ra hợp lệ	97,0%	100,0%

Lưu ý về tên gọi mô hình đối chứng: tuy tên tag mang hậu tố "-8b", lệnh ollama show --modelfile xác nhận mô hình gốc là Llama 3.2 bản 3B với khoảng 3,2 tỷ tham số. Lượng tử hóa chỉ thay đổi số bit biểu diễn mỗi trọng số, không làm thay đổi số tham số của mạng. Tên biến thể mô hình không phải lúc nào cũng phản ánh đúng quy mô thật.

Bốn máy ảo trên mạng host-only 192.168.100.0/24: SIEM Ubuntu Server .10 (6 GB, Wazuh 4.9.0 Docker) · nạn nhân Ubuntu .20 (2 GB, agent 4.9.0) · Kali .30 (2–3 GB, không cài agent) · nạn nhân phụ Windows 10 .40 (4 GB, agent 4.9.0). Mô-đun AI đặt trên máy vật lý .1 để dùng trực tiếp GPU.

Yêu cầu chức năng FR-01 ... FR-13 và yêu cầu phi chức năng

Mã	Yêu cầu chức năng	Ca kiểm thử	Kết quả
FR-01	Đọc cảnh báo từ Indexer, không thao tác thủ công	TC-01	Đạt
FR-02	Trích xuất đúng tập trường đã cấu hình	TC-01	Đạt
FR-03	Truy xuất tri thức tham chiếu (mô tả luật, MITRE)	TC-03	Đạt
FR-04	Sinh diễn giải đủ trường theo lược đồ	TC-01	Đạt
FR-05	Xác thực đầu ra, dự phòng nếu sai	TC-04	Đạt
FR-06	Đổi mô hình qua tham số cấu hình	TC-05	Đạt
FR-07	Chạy theo lô, tổng hợp kết quả	TC-02	Đạt
FR-08	Ghi vết xử lý (bấm đầu vào/ra, phiên bản, thời điểm)	TC-06	Đạt
FR-09	Tạo và lập lịch job phân tích theo lô từ dashboard	—	—
FR-10	Lưu trữ kết quả và cho phép tra cứu lại theo lịch sử	—	—
FR-11	Ghi nhận đánh giá của người phân tích, tách khỏi khuyến nghị AI	—	—
FR-12	Xuất kết quả phân tích kèm dấu vết SOC và nguồn gốc	—	—
FR-13	Gửi thông báo tóm tắt đã lọc qua kênh ngoài (tùy chọn)	—	—

YÊU CẦU PHI CHỨC NĂNG

- NFR-01** Dữ liệu không rời hạ tầng nội bộ
- NFR-02** Chống chen chỉ dẫn từ dữ liệu đầu vào
- NFR-03** Kết quả nhất quán giữa các lần chạy
- NFR-04** Xử lý đủ nhanh, gần thời gian thực
- NFR-05** Mở rộng cấu hình không sửa mã lõi
- NFR-06** Ghi vết không lưu nội dung nhạy cảm thô
- NFR-07** Giới hạn quyền: chỉ đọc, không ghi / thực thi
- NFR-08** Phục hồi khi lỗi: trả trạng thái rõ ràng

FR-09 đến FR-13 thuộc phần giao diện vận hành, đã cài đặt và chạy được nhưng không đưa vào bộ ca kiểm thử nhị phân của chương 4 — nhóm không tính chúng vào con số 8/8 đạt.

Danh sách 33 case, nhãn tham chiếu và dự đoán hai cấu hình

Case	Luật	Mức chuẩn	A (có RAG)	B (không RAG)
ssh-5503-01	5503	medium	medium	medium
ssh-5503-02	5503	medium	medium	medium
ssh-5503-03	5503	medium	medium	medium
ssh-5760-01	5760	medium	medium	medium
ssh-5760-02	5760	medium	medium	medium
ssh-5760-03	5760	medium	medium	low
ssh-5710-01	5710	medium	medium	medium
ssh-5710-02	5710	medium	low	medium
ssh-2502-01	2502	high	high	medium
ssh-5712-01	5712	high	medium	medium
ssh-40112-01	40112	high	high	medium
ssh-40112-02	40112	high	high	medium
fim-554-01	554	medium	low	low
fim-554-02	554	medium	low	low
fim-553-01	553	high	low	medium
benign-5715-01	5715	low	low	low
benign-5501-01	5501	low	low	medium

Case	Luật	Mức chuẩn	A (có RAG)	B (không RAG)
benign-5501-02	5501	low	medium	medium
benign-5502-01	5502	low	low	low
benign-5502-02	5502	low	low	low
benign-5402-01	5402	low	low	medium
benign-503-01	503	low	low	low
benign-23502-01	23502	low	từ chối	low
benign-23502-02	23502	low	low	low
benign-23502-03	23502	low	low	low
benign-23502-04	23502	low	low	medium
benign-23502-05	23502	low	medium	low
benign-23502-06	23502	low	low	low
ambiguous-506-01	506	medium	medium	low
ambiguous-510-01	510	high	medium	high
web-31101-01	31101	medium	low	medium
web-31151-01	31151	high	medium	medium
web-31105-01	31105	medium	medium	medium

Xanh = khớp mức chuẩn **Đỏ** = lệch mức · Phân bố nhãn: 13 thấp · 13 trung bình · 7 cao · A đúng 22/33, B đúng 19/33, hòa 20 case

Case truy xuất tăng cường làm tốt hơn và làm tệ hơn

A ĐÚNG • B SAI — 8 CASE

ssh-2502-01	cao	A giữ đúng mức cao; B hạ xuống trung bình
ssh-40112-01	cao	A giữ đúng mức cao; B hạ xuống trung bình
ssh-40112-02	cao	A giữ đúng mức cao; B hạ xuống trung bình
ssh-5760-03	trung bình	B hạ xuống mức thấp
benign-5501-01	thấp	B nâng lên mức trung bình
benign-5402-01	thấp	B nâng lên mức trung bình
benign-23502-04	thấp	B nâng lên mức trung bình
ambiguous-506-01	trung bình	B hạ xuống mức thấp

A SAI • B ĐÚNG — 5 CASE

ambiguous-510-01	cao	A hạ xuống trung bình; B đúng
ssh-5710-02	trung bình	A hạ xuống mức thấp; B đúng
web-31101-01	trung bình	A hạ xuống mức thấp; B đúng
benign-23502-05	thấp	A nâng lên trung bình; B đúng
benign-23502-01	thấp	A từ chối phân loại (unknown)

20 case còn lại: hai cấu hình cho cùng kết quả.

So với cấu hình C: A đúng và C sai ở 13 case, chiều ngược lại chỉ 2 case.

Xu hướng quan sát được: truy xuất tăng cường giữ đúng mức cao tốt hơn ở nhóm SSH, nhưng lại hạ mức ở hai case toàn vẹn tập tin và một case nhập nhầm. Với cỡ mẫu này, đây là quan sát định tính chứ chưa phải kết luận.

Cách tính McNemar và khoảng tin cậy Wilson 95%

BẢNG GHÉP CẶP — A SO VỚI B

	B đúng	B sai
A đúng	14 (hòa)	b = 8
A sai	c = 5	6 (hòa)

13 cặp bất đồng → $p = 0,58$

A SO VỚI C

13 case A đúng / C sai · 2 case ngược lại → 15 cặp bất đồng → $p = 0,0074$

CÔNG THỨC — KIỂM ĐỊNH CHÍNH XÁC HAI PHÍA

$$p = 2 \times P(X \leq \min(b, c) \mid n = b + c, p = 0,5)$$

Chỉ những case cho kết quả khác nhau mới mang thông tin; case hòa bị loại khỏi phép tính.

KHOẢNG TIN CẬY WILSON 95% CHO TỶ LỆ KHỚP

A — có RAG

49,6–80,2%

B — không RAG

40,8–72,8%

C — notmythos

19,8–50,4%

0% 25% 50% 75% 100%

Khoảng của A và B chồng lấn phần lớn — chưa tách bạch được. Khoảng của A và C gần như không chồng lấn.

NẾU HỢI ĐỒNG HỎI VỀ CỖ MẪU

Với 33 cảnh báo, khoảng tin cậy rộng khoảng 30 điểm phần trăm nên chênh lệch 9,1 điểm giữa A và B không thể tách bạch. Ước tính cần khoảng 200–300 cảnh báo để kết luận chắc chắn về ảnh hưởng của truy xuất tăng cường. Ngược lại, chênh lệch 33,4 điểm giữa A và C đủ lớn để vượt qua giới hạn cỡ mẫu này.

Ranh giới tin cậy và năm nhóm rủi ro khi đưa LLM vào hệ thống an toàn

VÙNG KHÔNG ĐÁNG TIN CẬY

- Nội dung cảnh báo và nhật ký gốc
- Kết quả truy xuất tri thức
- Mọi dữ liệu có nguồn gốc ngoài mô-đun

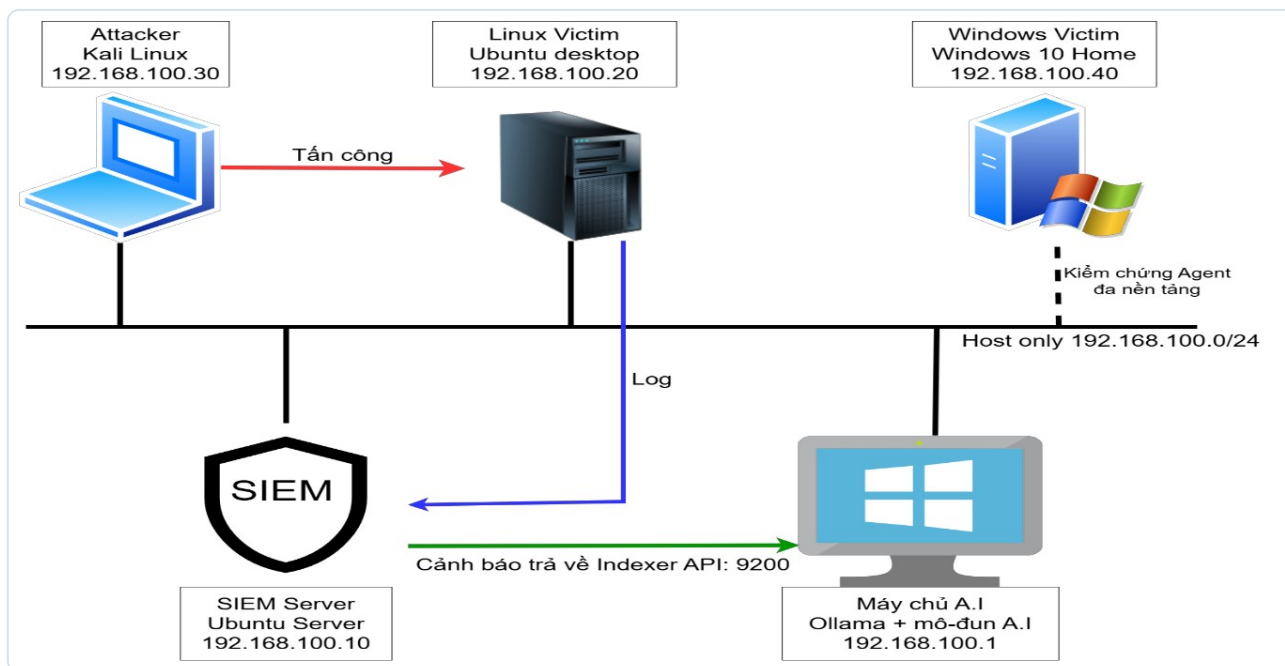
VÙNG ĐÁNG TIN CẬY

- Chỉ dẫn hệ thống soc-contract-v1
- Lược đồ đầu ra JSON Schema
- Mã nguồn xử lý do nhóm kiểm soát

Dữ liệu từ vùng không đáng tin cậy chỉ được đưa vào mô hình dưới dạng nội dung đã bọc trong ranh giới đánh dấu rõ ràng — không bao giờ nối trực tiếp vào chỉ dẫn hệ thống.

Nhóm rủi ro	Biện pháp kiểm soát đã áp dụng
Ảo giác — sinh thông tin hợp lý nhưng không có căn cứ	Truy xuất tri thức có nhãn nguồn; tách sự kiện quan sát khỏi suy luận; dùng "chưa xác định" khi thiếu bằng chứng
Chèn chỉ dẫn độc hại từ chính nội dung log	Bọc dữ liệu trong ranh giới đánh dấu tường minh, khai báo không đáng tin cậy, giới hạn quyền của mô hình
Rò rỉ dữ liệu nhạy cảm ra dịch vụ đám mây	Triển khai cục bộ; hàm kết nối chặn địa chỉ không phải localhost ngay ở tầng mã nguồn
Ghi vết vô tình lưu lộ dữ liệu nhạy cảm	Chỉ lưu giá trị băm SHA-256, không lưu văn bản gốc của phản hồi
Quá tin vào đầu ra của mô hình	Human-in-the-loop bắt buộc; hiển thị kèm dữ liệu gốc và song song mức do luật quy định

Sơ đồ mạng môi trường thử nghiệm và cây thư mục mã nguồn



Bốn máy ảo trên mạng host-only 192.168.100.0/24; mô-đun AI chạy trực tiếp trên máy vật lý .1

Mỗi máy ảo có thêm một card NAT riêng phục vụ tải cài đặt từ Internet, không tham gia luồng dữ liệu của hệ thống. Mô-đun AI đặt trên máy vật lý để dùng trực tiếp GPU, tránh chi phí ảo hóa phần cứng đồ họa.

```
local-ai-siem-analyzer/
├── infra/           cấu hình Docker Wazuh, netplan
├── scripts/
│   ├── setup/      install-wazuh.sh, install-agent.sh
│   └── attacks/    kịch bản sinh cảnh báo
├── ai_module/      mô-đun AI
│   ├── reader.py   đọc cảnh báo từ Indexer
│   ├── extractor.py trích 10 trường chính
│   ├── rag.py      ChromaDB + luật + MITRE
│   ├── llm.py      gọi Ollama, ép lược đồ
│   ├── main.py     điểm khởi chạy CLI
│   ├── analysis_service.py gom nhóm, điều phối
│   ├── dashboard.py API cục bộ loopback
│   ├── dashboard_store.py SQLite job / review
│   ├── dashboard_worker.py worker + lịch chạy
│   ├── create_rag_data.py sinh dữ liệu RAG
│   └── web/        HTML / CSS / JS thuần
├── eval/           33 case + bộ đánh giá
├── rag_data/       mô tả luật và bảng MITRE
├── tests/          kiểm thử tự động
└── docs/           tài liệu kỹ thuật
```

Sáu sự cố phát sinh khi triển khai và cách khắc phục

Sự cố	Nguyên nhân	Cách khắc phục
Mất IP tĩnh sau mỗi lần khởi động lại máy ảo	cloud-init tự sinh lại tệp cấu hình mạng, ghi đè cấu hình thủ công	Vô hiệu hóa cấu hình mạng của cloud-init bằng tệp ghi đè riêng
Các máy không ping được nhau dù IP đúng dải	VMware gán nhầm virtual switch khi đổi card mạng lúc máy đang chạy	Đổi tạm sang chế độ khác rồi đổi lại, tắt bật nguồn máy ảo
Cảnh báo có trong tệp cục bộ nhưng không hiện trên Dashboard	Filebeat trong Manager vẫn dùng mật khẩu mặc định sau khi đổi qua giao diện, gây lỗi xác thực 401 với Indexer	Đổi mật khẩu đồng bộ theo đúng quy trình ba nơi
Lỗi 500 khi truy cập Dashboard sau khi đổi mật khẩu	Cookie phiên cũ còn tồn tại trong trình duyệt	Đăng nhập lại bằng tab ẩn danh hoặc xóa cookie
Dashboard / Indexer hết thời gian chờ dù container vẫn chạy	Đĩa đầy do module dò quét lỗ hổng tích lũy dữ liệu CVE; mạng bridge của Docker hỏng sau đợt I/O nặng	Xóa thư mục dữ liệu CVE (tự tải lại được); khởi động lại Docker daemon để dựng lại bridge network
Module giám sát toàn vẹn không sinh cảnh báo dù kịch bản chạy đúng	Mặc định chỉ quét theo chu kỳ 12 giờ	Bật thuộc tính realtime="yes" trong ossec.conf

Phần lớn sự cố không xuất phát từ lỗi cấu hình đơn lẻ mà từ tương tác giữa các lớp — ảo hóa, container và cơ chế xác thực — nên khó phát hiện nếu chỉ đọc tài liệu chính thức.

Các lỗi thường gặp trong nội dung do mô hình sinh ra

Loại lỗi	Tần suất	Ví dụ cụ thể
Bịa tên hoặc bịa mã kỹ thuật MITRE	6/20 — 30%	T1053.002 gán sai tên "System Service Management" (case benign-503-01); T1070.002 sai tên (case fim-554-02)
Gán mã MITRE cho sự kiện lành tính hoặc chưa rõ	4/20 — 20%	T1190 gán cho một thông báo về lỗi hỏng đã được vá (case benign-23502-01 và -02)
Suy diễn vượt quá dữ liệu quan sát được	3/20 — 15%	Kết luận "đang bị dò mật khẩu" chỉ từ một lần đăng nhập thất bại (case ssh-5760-03)
Đề xuất bước kiểm tra lạc chủ đề	2/20 — 10%	Gợi ý kiểm tra "SQL injection, XSS" cho một cảnh báo về cập nhật gói phần mềm (case benign-23502-01)
Không nhất quán giữa các case cùng loại luật	3 nhóm luật	Cùng luật 23502 nhưng mức nghiêm trọng lần lượt là unknown và low, ánh xạ MITRE lúc có lúc không

Điểm chung của bốn nhóm lỗi đầu: mô hình gặp khó khăn nhiều hơn khi xử lý sự kiện KHÔNG có dấu hiệu tấn công rõ ràng, vì phải đưa ra kết luận "không có gì đáng ngại" thay vì gán một nhãn cụ thể — đây là hành vi mà mô hình ngôn ngữ có xu hướng thiên về hơn.

Hạn chế đã ghi nhận và bốn hướng phát triển tiếp theo

HẠN CHẾ ĐÃ GHI NHẬN

- 1 Phạm vi và quy mô dữ liệu đánh giá**
33 cảnh báo sinh từ kịch bản mô phỏng trong lab, chưa phản ánh hết tính đa dạng của vận hành thực tế.
- 2 Phương pháp chấm điểm**
Cả hai người chấm đều là người xây dựng hệ thống — tiềm ẩn thiên lệch dù đã dùng hệ số Kappa.
- 3 Quy trình chấm chưa có vòng hiệu chỉnh**
Chưa chấm thử trên tập nhỏ trước, chưa ghi lại tiêu chí phải phân xử.
- 4 Độ bao phủ kho tri thức**
19 tài liệu so với hàng nghìn luật Wazuh và hàng trăm kỹ thuật ATT&CK.
- 5 Kiểm chứng tái lập và an toàn**
Chưa chạy lặp nhiều lượt trên GPU; lớp chống chèn chỉ dẫn mới ở mức thiết kế, chưa đo bằng bộ dữ liệu đối kháng.
- 6 Chiều sâu phân tích tương quan**
Mới dừng ở thống kê theo cụm, chưa dựng được chuỗi tấn công theo trình tự nhân quả.

BỐN HƯỚNG PHÁT TRIỂN

- 1 Mở rộng bộ dữ liệu đánh giá**
Tăng cả quy mô lẫn độ đa dạng kịch bản; bổ sung cảnh báo thu từ vận hành thực tế.
- 2 Nâng cấp năng lực tương quan**
Dựng chuỗi tấn công theo trình tự nhân quả để hỗ trợ phát hiện tấn công nhiều bước.
- 3 Mở rộng kho tri thức tham chiếu**
Bổ sung khuyến cáo xử lý sự cố và dữ liệu lỗ hổng, kèm quy trình cập nhật định kỳ.
- 4 Mời người ngoài nhóm chấm độc lập**
Người có kinh nghiệm vận hành SOC chấm lại và tính lại hệ số đồng thuận.

Ngoài ra: đánh giá dưới tài thực tế và trên phần cứng cho phép chạy mô hình quy mô lớn hơn